



madhu m. kurup

Are all your eggs in one basket?

Familiarity breeds contempt. It also breeds virus and hacker attacks. Which is why diversity is the name of the game in network security

Normal is boring. Sometimes, though, normal can be more dangerous than just plain boring. Security depends on the attacker being as minimally aware of your information as possible. Highly diverse, dissimilar systems are likely to pose greater difficulty for an attacker than a standard, normal and expected configuration. From a security standpoint, being average is more than just being mean (pun unintended). Using similar application software, operating systems or even configurations is a probable cause for security issues. Thanks to the Internet, now we are much more closely connected than we actually believe or understand ourselves to be. This connection implies that problems in one configuration can migrate to another with ease.

The foremost tool used to externally analyse your machine is `nmap` (www.insecure.org/nmap). `Nmap` is a port scanner that can tell you exactly which OS and what services are operating on a given machine. Once an attacker is able to obtain information regarding the configuration of the machine, the situation changes. If the scan reveals the machine to be of a default or well-known configuration, scripts are usually available to attack it. These problems are not specific to just the Windows or just the Unix world, they are occurring with increasing frequency in both.

True, one would assume that there's a fair degree of diversity in the Windows world—after all, Windows is available as 3.1, 95, 98, CE, ME, NT, 2K, XP (with some of these in Home, Professional Server and Data Center variants). If that isn't enough, you may or may not have applied the various service packs supplied by Microsoft. Hang on, we aren't done yet—the IIS Web Server, IE and Outlook Express are available in a vari-

ety of versions as well. With so much diversity, we should be safe, right? But given the virus attacks that routinely cripple the Windows world, we realise the effects of having an OS based on a common family with similar security issues. Love Bug, Melissa and the KaK virus extracted a devastating price in terms of the damage they caused. The fact that Microsoft routinely creates software that allows malicious external code to be executed via an e-mail client is inexcusable; the rate at which these e-mail viruses spread is an even more serious cause for concern.

Another example of the implications of a Windows bug comes from a newly discovered exploit that affects IIS 5.0 servers. This bug is estimated to affect over a million servers world-wide. How many of these servers are likely to be patched in time to avoid automated tools that hunt for such servers is yet to be known. However, if you read the relevant Microsoft Security Bulletin, you will find that if you had not retained the defaults but had customised your IIS setup instead, this problem could have been avoided. The rate at which these infections spread reveals that monoculture, especially in an office or in an organisation, is a fertile breeding ground for an attack.

So, then, the Unix world is much safer, right? Well, not really. Linux is humorously described as the Unix de-fragmentation tool. And, for far too long, most new users seem to think that Red Hat is Linux and vice versa. The outbreak of the Ramen, LiOn and Adore (www.nipc.gov/warnings/alerts/2001/01-010.htm) worms indicates that Linux usage is also beginning to show a lack of diversity. These worms make use of the fact that machines are typically installed using the default Red Hat install—something that installs

